How-To Library

Informatica

How Secure@Source Calculates Risk Score

© Copyright Informatica LLC 2019, 2021. Informatica, the Informatica logo, and Secure@Source are trademarks or registered trademarks of Informatica LLC in the United States and many jurisdictions throughout the world. A current list of Informatica trademarks is available on the web at https://www.informatica.com/trademarks.html

Abstract

Secure@Source calculates a risk score for each data store and a risk score for the enterprise. To calculate the risk score, Secure@Source uses metrics such as the number of unprotected sensitive fields, the number of users with access to the data, and the measure of proliferation. Secure@Source also includes any user-defined metric in the risk score calculation. This article defines each metric and shows how each effects the risk score of a data store.

Supported Versions

- Secure@Source 5.0

Table of Contents

Risk Score Overview. 2
Risk Score Factors: Influencers. 4
Risk Factor Cause and Effect. 5
Sensitivity Level. 5
Protection Status. 7
Number of Sensitive Fields or Files. 8
Policy Impressions. 9
Number of Targets. 11
Residual Risk Cost. 11
User Access Count. 12
Impressions. 12
Custom Factor. 12
Steps to Refine the Risk Score Calculation. 14
Actions to Decrease Risk Score. 15

Risk Score Overview

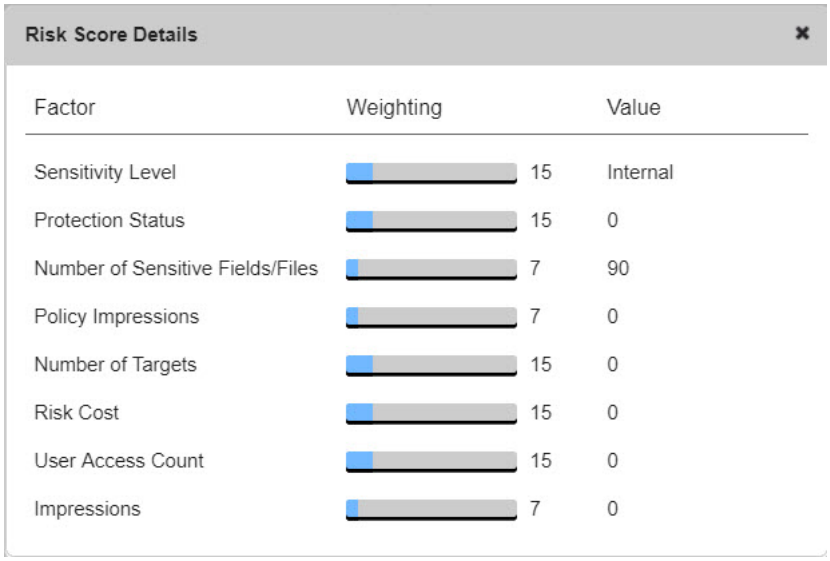
Secure@Source evaluates the risk of unprotected personal and sensitive data and provides a risk score, at the data store and enterprise level.

Secure@Source uses specific data store metrics, or risk factors, to calculate the risk score. For example, if the data store contains a large number of unprotected sensitive fields and many users have access to the data store, the risk score is high.

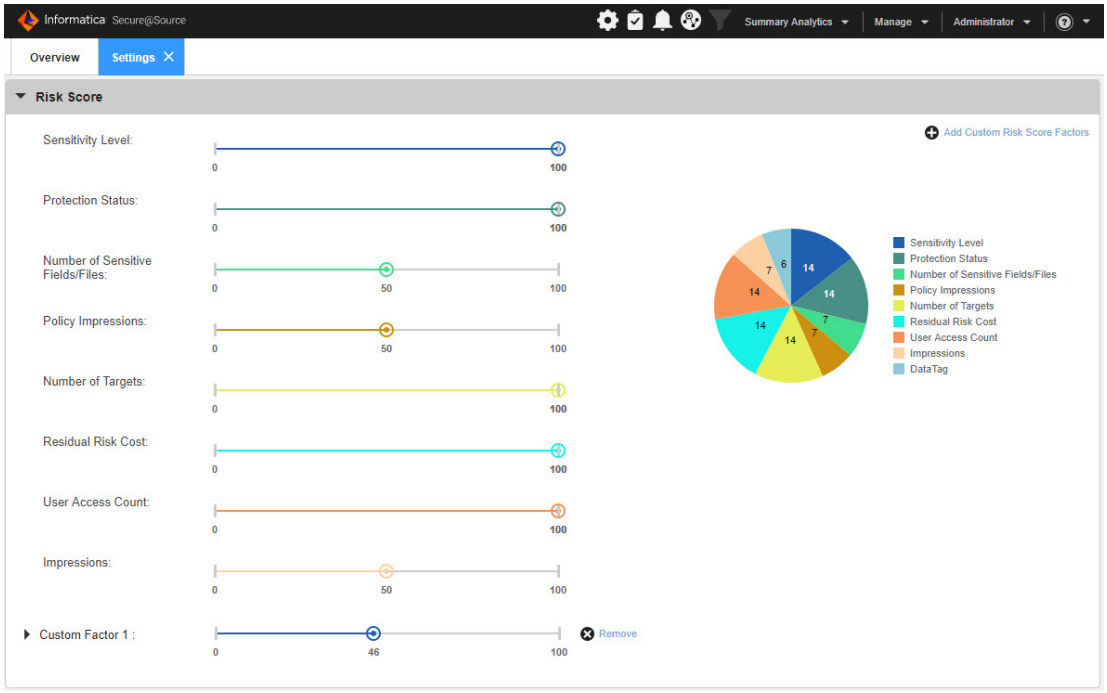
You can customize the risk score based on the security priorities in your company. You can adjust the weights, exclude factors, and add custom factors.

Informatica recommends that the relevant stakeholders in your company discuss the relative importance of each factor and reach consensus on a risk factor setting that is applicable across the organization.

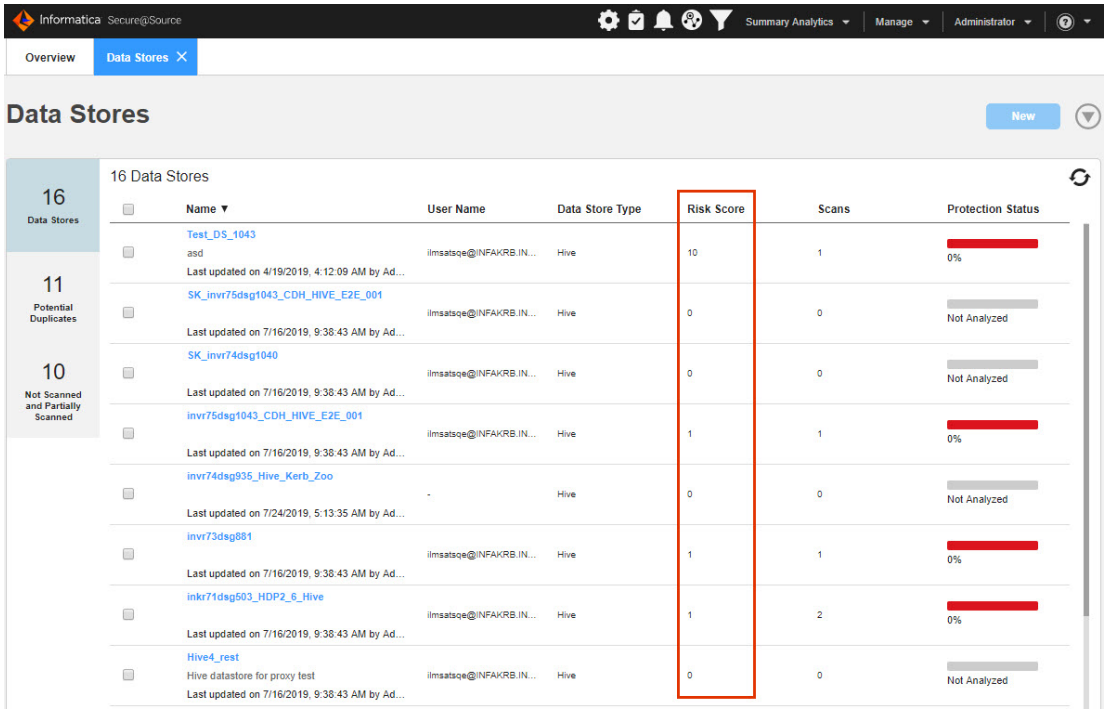
The risk score for the enterprise appears on the **Overview** workspace. To view the factors and weights that comprise the risk score, click the risk score value in the **Risk Score** indicator. The **Risk Score Details** window appears with the list of factors and weights:



To customize the risk factors, go to the **Settings** workspace and scroll to the **Risk Score** section.



To see the risk score for a data store, go to the **Data Stores List** page.



Risk Score Factors: Influencers

By default, Secure@Source uses a set of risk factors to determine the risk score of a data store. Each factor has a specific weight in the risk score formula.

The weight of a factor depends on the following aspects:

Slider value

The maximum weight for a factor in the risk score.

Each factor listed in the **Risk Score** section on the **Settings** workspace has a slider that ranges from 0 to 100. The number on the slider indicates the maximum weight of the risk factor in the formula. The pie chart shows the proportion of each factor's weight in the formula.

Based on your enterprise security priorities, you can use the slider to set the maximum weight for each factor. Alternatively, you can retain the default weights. To eliminate the factor from the formula, set the slider to zero.

The following table shows the risk factors, slider values, and weights used in the default risk score calculation:

Data Store Metric	Default Slider Value	Default Weight
Sensitivity level	100	15%
Protection status	100	15%
Number of sensitive fields or files	50	7%
Policy impressions	50	7%

Data Store Metric	Default Slider Value	Default Weight
Number of targets	100	15%
Residual risk cost	100	15%
User access count	100	15%
Impressions	50	7%

Factor value

The data store value of each factor. Based on the value, Secure@Source assigns a weight that is proportional to the factor value.

For example, sensitive data from the HR data store proliferated to more than 40 target data stores. Secure@Source defines 40 or more targets as high-risk and consequently assigns the maximum specified weight for the **Number of Targets** factor in the formula.

Weight of other factors

Because the weights of all included factors must total 100, each factor's weight is inversely proportional to the total weight of the other factors in the formula.

For example, if you include all the standard risk factors and set the slider value of each factor to 100, the weight of each factor is 12%. If you exclude two factors by setting the slider value to 0, the weight of these two factors is 0 and the weight of each of the remaining factors increases to 16%.

Mathematical function in the formula

A factor can have an additive, multiplicative, or exponential function in the formula. An exponential factor imposes a greater influence on the formula than a factor with a multiplicative or additive function.

Risk Factor Cause and Effect

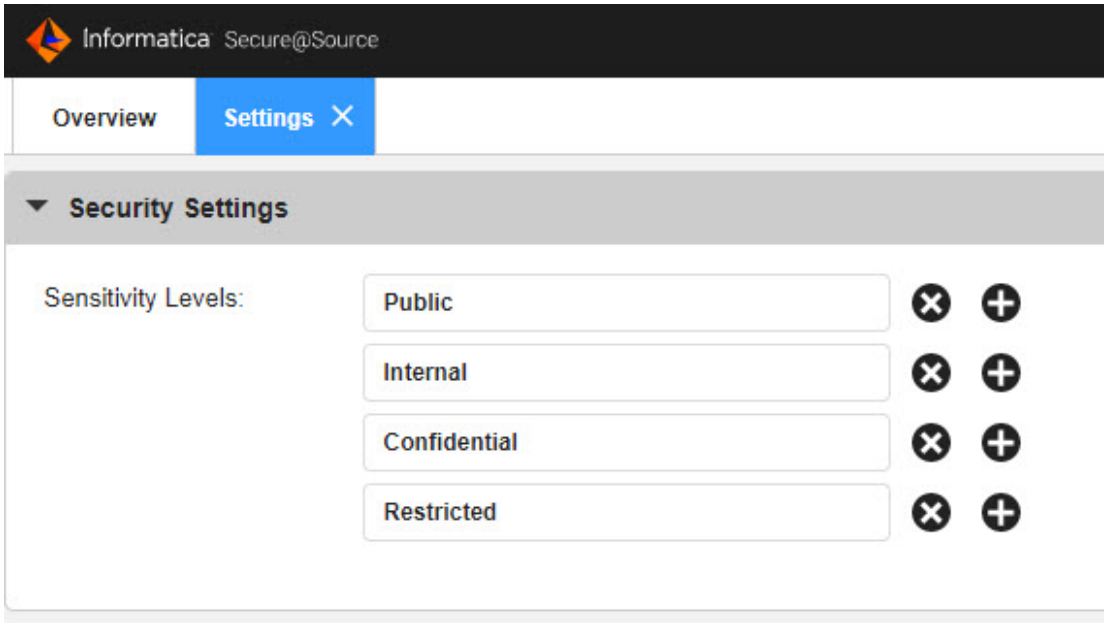
The following sections explain the risk factors and how Secure@Source determines a value for each factor.

Sensitivity Level

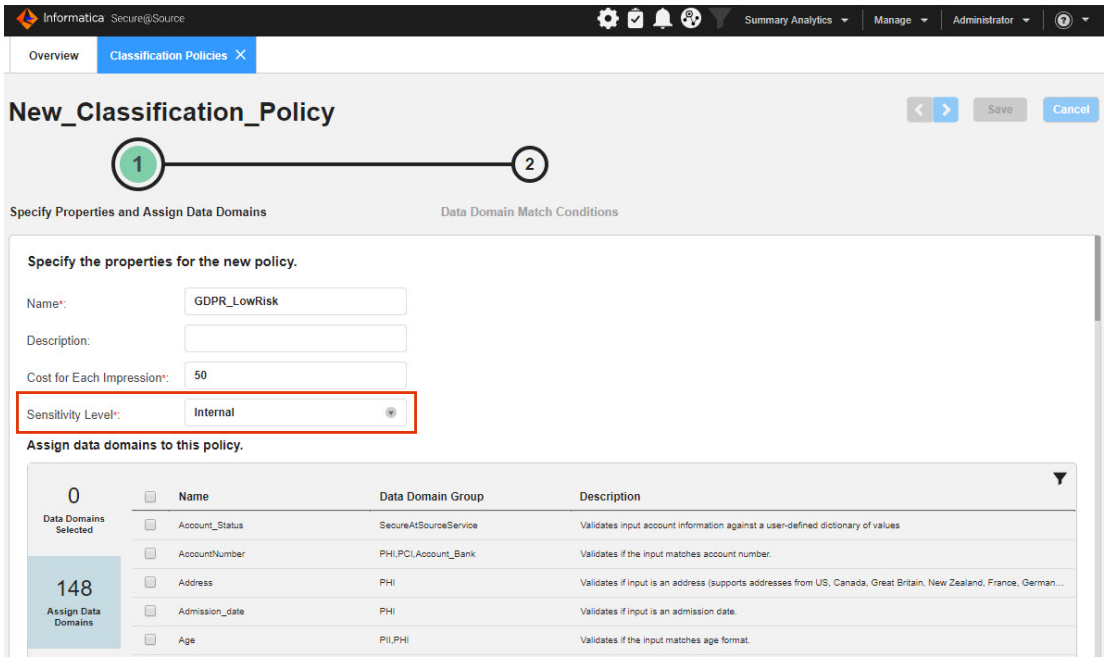
Definition

The highest sensitivity level among the classification policies that match the data store.

You set the name and number of the sensitivity levels in the **Security Settings** section of the **Settings** workspace.



You specify a sensitivity level when you define a classification policy.



Example

You specify four sensitivity levels from least to most severe on the **Settings** workspace. You name the most severe level Restricted. You create classification policies and assign a sensitivity level to each policy. You scan the HR data

store with different classification policies. The HR data store matches the following classification policies with the respective sensitivity levels:

Classification Policy	Sensitivity Level
GDPR_LowRisk	Internal
PII	Confidential
PII_HighRisk	Restricted

Because Restricted is the highest matched sensitivity level, Secure@Source assigns the Restricted sensitivity level to the HR data store. Because Restricted is the highest sensitivity level, Secure@Source sets the factor to the maximum weight in the risk score formula.

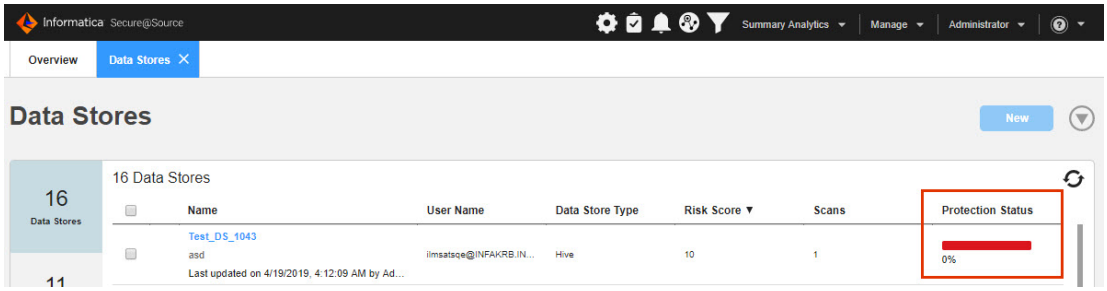
Function in Formula

Additive.

Protection Status

Definition

The percentage of unprotected fields in a data store that match data domains in the classification policy used in the scan. The higher the percentage, the higher the risk.



Based on the percentage of unprotected fields, Secure@Source assigns a proportional weight for the factor in the risk score formula.

Example

The Finance data store has 100 fields. You scan the data store with the PCI classification policy. Twenty fields match one or more of the data domains in the PCI classification policy. Five of the 20 fields are protected. Because 15 of the 20 fields are not protected, Secure@Source assigns a Protection Status factor value of 75% and a proportional weight in the risk score formula.

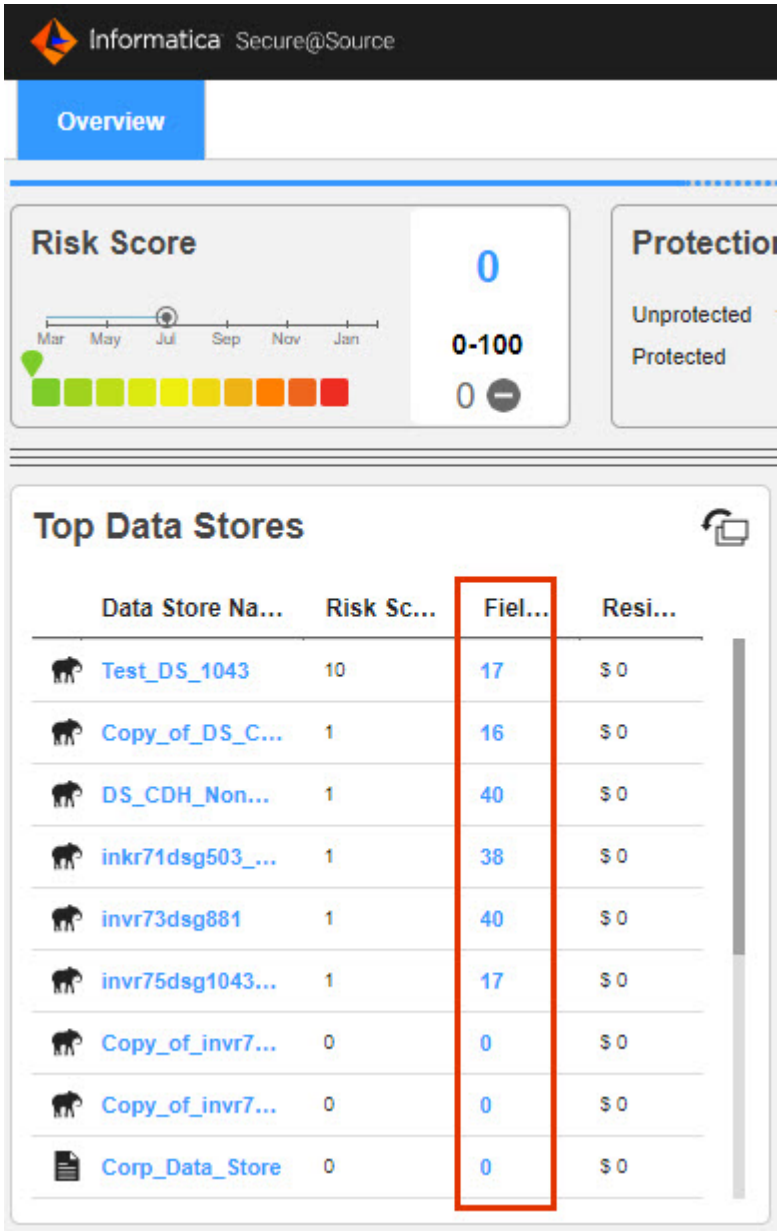
Function in Formula

Additive.

Number of Sensitive Fields or Files

Definition

The number of distinct sensitive fields in the data store or the number of files.



Based on the number of sensitive fields or files, Secure@Source assigns a proportional weight for the factor in the risk score formula.

Example

Your data store has 100 fields. You scan the data store with the PHI classification policy and discover 10 sensitive fields. You scan the data store with the GDPR classification policy and discover 15 sensitive fields. However, five of these fields overlap with the previous scan. Secure@Source counts the number of distinct fields and assigns a Number of Sensitive Fields or Files factor value of 20. Secure@Source assigns a proportional weight in the risk score formula.

Function in Formula

Exponential.

Policy Impressions

Definition

The number of distinct records, called impressions, that match the data domain match condition specified in the classification policy.

First, Secure@Source determines the impression count at the data domain level. The data domain impression count is the sum of the unique values in each field that match the data domain.

Next, Secure@Source uses the data domain impression count and the data domain match condition in the classification policy to determine the policy impressions.

Based on the policy impression count, Secure@Source assigns a proportional weight for the factor in the risk score formula.

The following examples explain how Secure@Source calculates the impression count at the data domain level and the policy level.

Example: Data Domain Impression Count

You use the PII classification policy in a data profile scan. The classification policy includes the following data domains:

- BirthDate
- SSN
- LastName

During the scan, Secure@Source determines the fields that match each data domain. Secure@Source counts the number of unique values in each matched field and excludes null or duplicate values.

To illustrate how Secure@Source determines the data domain impression count, consider the BirthDate data domain.

The following table shows the fields that matched the BirthDate data domain:

Field Name	Number of unique values
Birthday	150
Date_of_Birth	200
Birth_Date	175
	Total = **525**

Secure@Source determines the sum of unique values in the matched fields to determine the BirthDate data domain impression count. Similarly, Secure@Source determines the impression count for the SSN and LastName data domains.

The following table shows the impression count for the example data domains:

Data Domain	Impression Count
BirthDate	525
SSN	400
LastName	650

Next, Secure@Source evaluates the data domain match condition of the classification policy.

Example: Classification Policy Impression Count

Depending on the data domain match condition, the policy impression count is equal to the impression count of the data domain with either the most or the least impressions.

The following sections show the policy impression count for the different data domain conditions.

Note: These sections use the data domain impression count in the **Example: Data Domain Impression Count** section.

Match Any

This condition is met if Secure@Source finds a match for at least one data domain in the classification policy. The policy impression count equals the impression count of the data domain with the **most** impressions.

The following table shows the policy impression count for different outcomes:

If...	The Policy Impression Count is...
Secure@Source finds a match for only the BirthDate data domain.	525
Secure@Source finds a match for the SSN and LastName data domains.	650
Secure@Source finds a match for the BirthDate, SSN, and LastName data domains.	650

Match All

This condition is met if Secure@Source finds a match for all the data domains in the classification policy. The policy impression count equals the impression count of the data domain with the **least** impressions.

If Secure@Source finds a match for the example BirthDate, SSN, and LastName data domains, the policy impression count is 400.

Custom Condition with the All-Are-True Operator

User-defined condition that is met if Secure@Source finds a match for all the data domains linked with the **All are true** operator. This condition is the same as the Match All condition. The policy impression count equals the impression count of the data domain with the **least** impressions.

Custom Condition with the Any-Is-True Operator

User-defined condition that is met if Secure@Source finds a match for any one data domain linked to other data domains with the **Any is true** operator. This condition is the same as the Match Any condition. The policy impression count equals the impression count of the data domain with the **most** impressions.

Function in Formula

Exponential.

Number of Targets

Definition

The number of target data stores to which one or more sensitive fields proliferated. The larger the number of targets, the higher the risk.

Based on the number of targets, Secure@Source assigns a proportional weight for the factor in the risk score formula.

Example

The Finance data store has 20 sensitive fields. From Informatica PowerCenter mappings, Secure@Source discovers that some of the sensitive fields were copied to a total of 12 data stores. Secure@Source assigns a Number of Targets factor value of 12 and a proportional weight in the risk score formula.

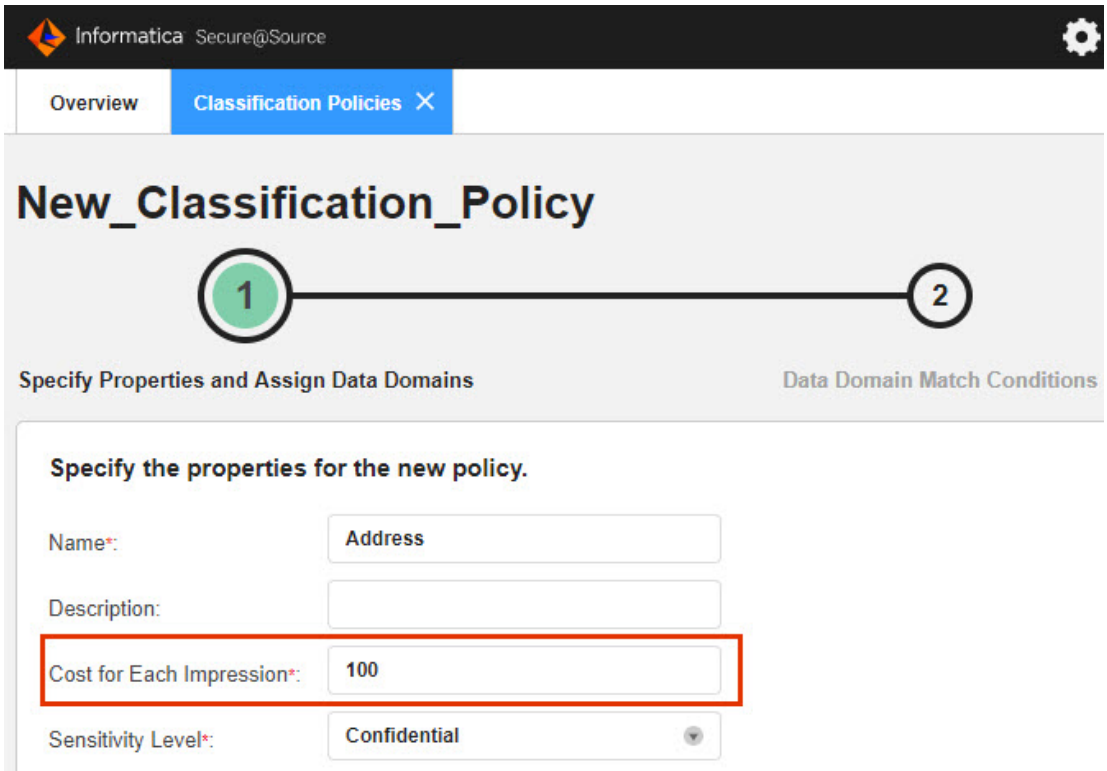
Function in Formula

Additive.

Residual Risk Cost

Definition

The amount of money it would take to resolve the problems of a data breach involving unprotected sensitive data. You specify the cost of an unprotected sensitive impression in the classification policy.



To calculate risk cost, Secure@Source counts the number of unprotected sensitive values to determine the data domain and the classification policy impression counts. Then, Secure@Source multiplies the number of policy impressions with the cost of a single unprotected sensitive impression that you specified in the classification policy.

Based on the cost, Secure@Source assigns a proportional weight for the factor in the risk score formula.

Example

The Finance data store is a match for the PCI classification policy. Secure@Source finds 50,000 unprotected sensitive impressions. The cost for an impression specified in the PCI classification policy is $50. Secure@Source assigns a Residual Risk Cost factor value of $2,500,000 and a proportional weight in the risk score formula.

Function in Formula

Additive.

User Access Count

Definition

The number of users with an active status and with access to the data store. The larger the number of active users, the higher the risk.

Based on the number of active users, Secure@Source assigns a proportional weight for the factor in the risk score formula.

Example

Based on an LDAP import, 400 employees can access the data store. However, the status for 30 of the employees is set to Inactive. Secure@Source assigns a User Access Count factor value of 370 and a proportional weight in the risk score formula.

Function in Formula

Additive.

Impressions

Definition

The number of unprotected sensitive impressions in the data store that users accessed. The higher the number of unprotected sensitive impressions accessed, the higher the risk.

Based on the number of accessed impressions, Secure@Source assigns a proportional weight for the factor in the risk score formula.

Example

Based on user activity data streamed to Secure@Source, employees accessed 9,000 sensitive impressions. You import protection status to specify that three fields are protected. These three fields include 3,000 of the 9,000 accessed impressions. Secure@Source assigns an Impressions factor value of 6,000 and a proportional weight in the risk score formula.

Function in Formula

Exponential.

Custom Factor

Definition

A user-defined factor to assess a risk not captured by the Secure@Source standard risk factors. When you define the factor, you provide the name and weight for the factor. You can create up to five custom factors.

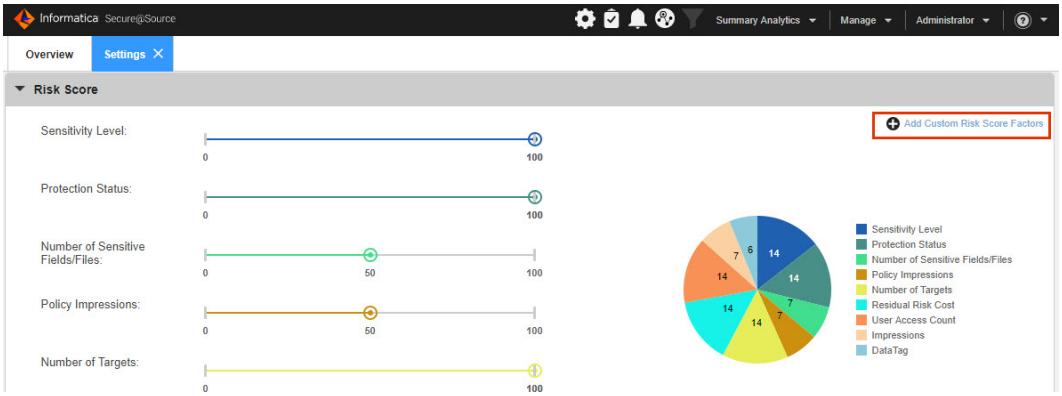
For each custom factor, you can specify between two and five values or ranges. One value or range must have a weight of 0 to indicate the least impact on risk score. Another value or range must have a weight of 100 to indicate the maximum impact on risk score.

Example

Your data stores include production or test data. The test data stores contain production data that might or may not be masked. You want the risk score to factor in the risk based on this variance in the data stores.

You perform the following steps:

1. From the **Risk Score** section on the **Settings** workspace, you click **Add Custom Risk Score Factors**.



2. You name the factor **Data Type Tag**.
3. You specify a weight of **40** for the factor.
4. You specify a value and weight for each type of data.
   Because a breach to production data is the riskiest, you assign the maximum weight of 100 to production data. Because test data stores with fully masked production data have the least risk, you assign the minimum weight of 0 to fully protected test data stores.

   The following table shows the values and weights you set for the **Data Type Tag** risk factor:

Value	Weight
Test - All Masked	0
Test - Subset Masked	35
Test - Subset Not Masked	80
Production	100

5. You select **Production** as the default value for all future data stores.
   The following image shows the details of the example custom factor:



When you save the custom factor, Secure@Source performs the following tasks:

1. Adds the custom factor as a property to existing and new data stores. In this example, Secure@Source adds the property **Data Type Tag** to data stores.
2. When a new data store is created, Secure@Source assigns the default value to the property. In this example, Secure@Source assigns the value **Production** to the **Data Type Tag** property.

   Note: For existing data stores, Secure@Source does not assign a value to the custom factor property. You must edit the data store and select a value for the property.
3. Secure@Source uses the weight of the custom factor value in the data store to determine the impact of the custom factor in the risk score formula.
   In this example, Secure@Source determines the weight of the **Data Type Tag** factor in the risk score formula as follows:

Value of custom factor in the data store	Weight of custom factor	Impact on risk score formula
Test - All Masked	0	No impact.
Test - Subset Masked	14	Moderate.
Test - Subset Not Masked	32	High.
Production	40	Maximum specified weight for factor.

Function in Formula

Additive.

Steps to Refine the Risk Score Calculation

You can refine and customize the risk score in the following ways:

- Define data domains.
- Define classification policies with the correct cost for each impression, sensitivity level, data domains, and match conditions.
- Scan the data store with the appropriate classification policies.
- Import any changes to sensitivity or protection status.
- Import custom lineage.
- Import a white list and a black list.
- Verify that the list of active users and permissions are correct.
- Stream user activity.
- From the Settings page, set the slider value of each factor based on importance. To remove factors that are not relevant, set the weight of the factor to zero.
- Optionally, add one or more custom factors.

When you change the weights or you include or exclude risk score factors from the Settings page, the Secure@Source Service performs the following actions:

- Uses the new settings to calculate the risk score of data stores in future scans.
- Starts the Recalculate Risk Scores job to calculate and update the risk scores of previously scanned data stores.

- Updates the new risk scores in the Secure@Source repository.
- Updates the new risk scores on the dashboard, the scan details page, and the data store list page.
- Displays the custom factor on the data store details page for existing and future data stores.
- Displays the default value of the custom factor on the data store details page for future data stores.

Actions to Decrease Risk Score

You can perform the following actions to reduce the risk score for a data store:

- Improve data quality. Remove redundant data that might inflate the number of sensitive fields and impressions.
- Protect sensitive data. For information on how to protect data with Secure@Source, see the *Informatica Secure@Source 5.0 Guide*.
- Mitigate unnecessary data proliferation.
- Evaluate user accounts and restrict access to sensitive data as necessary.

Author

Secure@Source R&D Team